# itsdangerous cram sheet

pallets/itsdangerous@2.3.0.dev (672971d) · 2026-11-02

**If you only read one thing:** tokens are signed, not encrypted: anyone can read the payload. Always catch `BadSignature` from `loads`.

Legend: ★ most used · ⚠ gotcha

## SIGN AND VERIFY ★

```
from itsdangerous import (
  URLSafeSerializer)
s = URLSafeSerializer(
  SECRET_KEY, salt="auth")
tok = s.dumps({"id": 5})
s.loads(tok)  # {'id': 5}
```

`pip install itsdangerous` · Python 3.10+

## EXPIRING LINKS ★

```
from itsdangerous import (
  URLSafeTimedSerializer)
s = URLSafeTimedSerializer(
  SECRET_KEY, salt="reset")
tok = s.dumps("a@b.com")
s.loads(tok, max_age=3600)
```

`return_timestamp=True` → `(data, datetime)` in UTC.

## PICK A CLASS

- `URLSafeSerializer` ★: JSON → URL-safe str
- `URLSafeTimedSerializer` ★: adds timestamp for `max_age`
- `Serializer`: raw JSON + sig, not URL-safe
- `Signer`: bytes → `b"value.sig"`
- `TimestampSigner`: Signer + timestamp

## EXCEPTIONS

- `BadData`: base of all; catch this for everything
- `BadSignature`: tampered, wrong key or salt
- `SignatureExpired`: older than `max_age`, or future-dated
- `BadPayload`: sig OK, decode failed

`e.payload`: unverified data.
`e.date_signed`: when signed (UTC).

## TOKEN ANATOMY

`payload.timestamp.signature`

- payload: base64 of compact JSON; leading `.` = zlib-compressed
- timestamp: timed classes only
- signature: HMAC over everything before it

## KEYS AND SALTS

- Key: random, from env, never in git: `os.urandom(16).hex()`
- Salt: not secret, one per purpose, so a reset token can't confirm an email.
- Rotate: pass `[old, new]`. Signs with last, verifies with all.
- Changing key or salt kills all live tokens.

## CHANGE THE HASH

```
from hashlib import (
  sha1, sha512)
URLSafeSerializer(KEY,
 signer_kwargs={
  "digest_method": sha512},
 fallback_signers=[{
  "digest_method": sha1}])
```

Default HMAC-SHA1 is safe; SHA-512 makes tokens longer.

## GOTCHAS

- ⚠ `ts.loads(tok, "salt")` puts salt in `max_age` → `TypeError`, because `max_age` is the 2nd param. Use keywords.
- ⚠ No `max_age` = never expires, because the timestamp is only checked on request.
- ⚠ JSON: tuples come back as lists; sets raise `TypeError`.
- ⚠ `BadPayload` is not a `BadSignature`; catch `BadData` for both.
- ⚠ `Signer` default salt is `itsdangerous.Signer`, `Serializer` is `itsdangerous`: same key, different sigs.
- ⚠ `loads_unsafe` skips the check: debug only, never with pickle.

## HACK ON THE REPO

| Command | Does |
|---|---|
| `uv sync` | make .venv |
| `uv run tox run -e py3.13` | tests |
| `uv run tox run -e style` | ruff, hooks |
| `uv run tox run -e typing` | mypy, pyright |

No uv: `pip install -e . pytest freezegun`, then `pytest`.

Warnings fail pytest. Add a `CHANGES.rst` entry.

## RARER OPTIONS

- `Signer(sep=...)`: not a letter, digit or `-_=`, else `ValueError`
- `key_derivation`: `django-concat` (default), `concat`, `hmac`, `none`
- `dump(obj, f)` / `load(f)`: file variants of `dumps` / `loads`